



Individual Assignment – Scanning Result

CT123-3-3

ADVANCED SOFTWARE SECURITY

APD3F2509CS(CYB)

HAND OUT DATE : 25th March 2026

HAND IN DATE : 06th May 2026

WEIGHTAGE : 20%

LECTURER : NIK SAKINAH BINTI NIK AB AZIZ

STUDENT NAME : HO ZHEN XUAN (TP073918)

INSTRUCTIONS TO CANDIDATES:

- 1. Assignment is to be submitted through online submission (Moodle).**
- 2. Student are advised to underpin their answers with the use of references (cited using the Harvard Name System of Referencing).**
- 3. Late submissions will be awarded zero (0) unless Extenuating Circumstances (EC) are up help.**
- 4. Cases of plagiarism will be penalized.**
- 5. You must obtain 50% overall to pass this module.**

Semgrep Scanning Result

24	Improper Authorization (AUTHZ) Improper authorization vulnerability that may allow an attacker to access sensitive data or perform actions they shouldn't be able to.		SecurityHigh</>GenericDetected by AI			
	2d	frontend/src/Pages/Dashboard/.../Return.js:79	superuser	ASCASM	main	OPEN
	2d	frontend/src/Pages/Dashboard/.../Return.js:61	superuser	ASCASM	main	OPEN
	2d	frontend/src/Pages/Dashboard/.../AddTransaction.js:61	superuser	ASCASM	main	OPEN
	2d	frontend/src/Pages/Dashboard/.../AddTransaction.js:57	superuser	ASCASM	main	OPEN
	2d	frontend/src/Pages/Dashboard/.../AddBook.js:56	superuser	ASCASM	main	OPEN
	2d	backend/server.js:25		ASCASM	main	OPEN
	2d	backend/server.js:24		ASCASM	main	OPEN
	2d	backend/server.js:23		ASCASM	main	OPEN
	2d	backend/server.js:22		ASCASM	main	OPEN
	2d	backend/server.js:21		ASCASM	main	OPEN
	2d	backend/routes/users.js:90	user authorization	ASCASM	main	OPEN
	2d	backend/routes/users.js:72	user authorization	ASCASM	main	OPEN
24	Improper Authorization (AUTHZ) Improper authorization vulnerability that may allow an attacker to access sensitive data or perform actions they shouldn't be able to.		SecurityHigh</>GenericDetected by AI			
	2d	backend/routes/users.js:55	user authorization	ASCASM	main	OPEN
	2d	backend/routes/users.js:30	user authorization	ASCASM	main	OPEN
	2d	backend/routes/users.js:19	user authorization	ASCASM	main	OPEN
	2d	backend/routes/transactions.js:57	user authorization	ASCASM	main	OPEN
	2d	backend/routes/transactions.js:43	user authorization	ASCASM	main	OPEN
	2d	backend/routes/transactions.js:33	user authorization	ASCASM	main	OPEN
	2d	backend/routes/transactions.js:7	user authorization	ASCASM	main	OPEN
	2d	backend/routes/categories.js:15		ASCASM	main	OPEN
	2d	backend/routes/books.js:87	user authorization	ASCASM	main	OPEN
	2d	backend/routes/books.js:69	user authorization	ASCASM	main	OPEN
	2d	backend/routes/books.js:42	user authorization	ASCASM	main	OPEN
	2d	backend/routes/auth.js:8	user authentication	ASCASM	main	OPEN
1	Insecure Direct Object Reference (IDOR) Insecure Direct Object Reference (IDOR) vulnerability that may allow an attacker to access sensitive data or perform actions they shouldn't be able to.		SecurityHigh</>GenericDetected by AI			
	2d	backend/routes/users.js:7	user authorization	ASCASM	main	OPEN
7	Critical@babel/traverse: Incomplete List of Disallowed Inputs EPSS: <0.1% (Low) CVE 2023-45133					
	2d	frontend/yarn.lock:1070	Needs review	Transitive	ASCASM	mainOPEN
	2d	frontend/yarn.lock:861	Needs review	Transitive	ASCASM	mainOPEN
	2d	frontend/yarn.lock:933	Needs review	Transitive	ASCASM	mainOPEN
	2d	frontend/yarn.lock:142	Needs review	Transitive	ASCASM	mainOPEN
	2d	frontend/yarn.lock:2841	Needs review	Transitive	ASCASM	mainOPEN
	2d	frontend/yarn.lock:2850	Needs review	Transitive	ASCASM	mainOPEN
	2d	frontend/yarn.lock:2858	Needs review	Transitive	ASCASM	mainOPEN
	Hide findings					
1	Criticalmongoose: Prototype Pollution EPSS: 0.5% (Low) CVE 2023-3696					
	2d	backend/yarn.lock:754	Reachable	Direct	ASCASM	mainOPEN

28	axios: Improper Check for Unusual or Exceptional Conditions EPSS: <0.1% (Low) CVE 2026-25639
2d	frontend/src/Pages/Dashboard/.../AddBook.js:28 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddBook.js:56 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddBook.js:79 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddMember.js:58 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddMember.js:91 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddTransaction.js:41 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddTransaction.js:42 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddTransaction.js:57 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddTransaction.js:61 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddTransaction.js:66 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddTransaction.js:100 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddTransaction.js:117 ReachablesuperuserDirectASCASMPmainOPEN

28	axios: Improper Check for Unusual or Exceptional Conditions EPSS: <0.1% (Low) CVE 2026-25639
2d	frontend/src/Pages/Dashboard/.../AddTransaction.js:133 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../AddTransaction.js:150 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../GetMember.js:20 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../GetMember.js:37 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../Return.js:26 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../Return.js:43 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../Return.js:61 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../Return.js:68 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../Return.js:73 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../Return.js:79 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../Return.js:85 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../Return.js:86 ReachablesuperuserDirectASCASMPmainOPEN

2d	frontend/src/Pages/Dashboard/.../Return.js:92 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../Return.js:107 ReachablesuperuserDirectASCASMPmainOPEN
2d	frontend/src/Pages/Dashboard/.../MemberDashboard.js:29 ReachablePIIDirectASCASMPmainOPEN
2d	frontend/src/Pages/SignIn.js:20 Reachableuser authenticationDirectASCASMPmainOPEN

1	rollup: Cross-site Scripting EPSS: 2.8% (Low) CVE 2024-47068
2d	frontend/yarn.lock:10150 Needs reviewTransitiveASCASMPmainOPEN

1	rollup: Path Traversal EPSS: 0.4% (Low) CVE 2026-27606
2d	frontend/yarn.lock:10150 Needs reviewTransitiveASCASMPmainOPEN

1	CORS Misconfiguration with Express ProSecurityHighJavaScript Having default CORS settings is insecure because they often allow overly permissive cross-origin access, exposing your application to unauthorized data sharing, potentially exposing sensitive data to malicious websites. Avoid using wildcard (*) origins, especially for endpoints that handle sensitive data. Use a restrictive CORS policy by explicitly specifying Show more
2d	backend/server.js:18 ASCASMPmainOPEN

3	@babel/helpers: Inefficient Regular Expression Complexity	EPSS: <0.1% (Low) CVE 2025-27789
	2d frontend/yarn.lock:288	Needs review Transitive ASCASM main OPEN
	2d frontend/yarn.lock:1054	Needs review Transitive ASCASM main OPEN
	2d frontend/yarn.lock:1046	Needs review Transitive ASCASM main OPEN
3	postcss: Cross-site Scripting	EPSS: <0.1% (Low) CVE 2026-41305
	2d frontend/yarn.lock:9223	Needs review Transitive ASCASM main OPEN
	2d frontend/yarn.lock:9232	Needs review Transitive ASCASM main OPEN
	2d frontend/yarn.lock:9240	Needs review Transitive ASCASM main OPEN
2	express: Improper Validation of Syntactic Correctness of Input	EPSS: 0.2% (Low) CVE 2024-29041
	2d frontend/yarn.lock:5111	Needs review Transitive ASCASM main OPEN
	2d backend/yarn.lock:389	Needs review Direct ASCASM main OPEN
2	micromatch: Inefficient Regular Expression Complexity	EPSS: 0.1% (Low) CVE 2024-4067
	2d frontend/yarn.lock:7658	Needs review Transitive ASCASM main OPEN
	2d frontend/yarn.lock:7677	Needs review Transitive ASCASM main OPEN
2	lodash: Prototype Pollution	EPSS: <0.1% (Low) CVE 2025-13465
	2d frontend/yarn.lock:7509	Needs review Transitive ASCASM main OPEN
	2d frontend/yarn.lock:7459	Needs review Transitive ASCASM main OPEN
2	ajv: Inefficient Regular Expression Complexity	EPSS: <0.1% (Low) CVE 2025-69873
	2d frontend/yarn.lock:2423	Needs review Transitive ASCASM main OPEN
	2d frontend/yarn.lock:2433	Needs review Transitive ASCASM main OPEN
2	bn.js: Infinite Loop	EPSS: <0.1% (Low) CVE 2026-2739
	2d frontend/yarn.lock:3009	Needs review Transitive ASCASM main OPEN
	2d frontend/yarn.lock:3014	Needs review Transitive ASCASM main OPEN
2	picomatch: Prototype Pollution	EPSS: <0.1% (Low) CVE 2026-33672
	2d frontend/yarn.lock:8504	Needs review Transitive ASCASM main OPEN
	2d backend/yarn.lock:940	Needs review Transitive ASCASM main OPEN
2	brace-expansion: Uncontrolled Resource Consumption	EPSS: <0.1% (Low) CVE 2026-33750
	2d frontend/yarn.lock:3059	Needs review Transitive ASCASM main OPEN
	2d backend/yarn.lock:157	Needs review Transitive ASCASM main OPEN
2	serialize-javascript: Uncontrolled Resource Consumption	EPSS: <0.1% (Low) CVE 2026-34043
	2d frontend/yarn.lock:10359	Needs review Transitive ASCASM main OPEN
	2d frontend/yarn.lock:10366	Needs review Transitive ASCASM main OPEN
2	lodash: Prototype Pollution	EPSS: <0.1% (Low) CVE 2026-2950
	2d frontend/yarn.lock:7509	Needs review Transitive ASCASM main OPEN
	2d frontend/yarn.lock:7459	Needs review Transitive ASCASM main OPEN

2	uuid: Improper Validation of Specified Index, Position, or Offset in Input	GHSAw5hq-g745-h8pq
2d	frontend/yarn.lock:11569	Needs reviewTransitiveASCAMPmainOPEN
2d	frontend/yarn.lock:11574	Needs reviewTransitiveASCAMPmainOPEN
1	browserslist: Inefficient Regular Expression Complexity	EPSS: 0.5% (Low) CVE2021-23364
2d	frontend/yarn.lock:3161	Needs reviewTransitiveASCAMPmainOPEN
1	node-forge: Improper Verification of Cryptographic Signature	EPSS: 0.1% (Low) CVE2022-24773
2d	frontend/yarn.lock:7948	Needs reviewTransitiveASCAMPmainOPEN
1	word-wrap: Inefficient Regular Expression Complexity	EPSS: <0.1% (Low) CVE2023-26115
2d	frontend/yarn.lock:11886	Needs reviewTransitiveASCAMPmainOPEN
1	@adobe/css-tools: Inefficient Regular Expression Complexity	EPSS: 0.3% (Low) CVE2023-26364
2d	frontend/yarn.lock:5	Needs reviewTransitiveASCAMPmainOPEN
1	follow-redirects: Exposure of Sensitive Information to an Unauthorized Actor	EPSS: 0.9% (Low) CVE2024-28849
2d	frontend/yarn.lock:5350	Needs reviewTransitiveASCAMPmainOPEN
1	ejs: Prototype Pollution	EPSS: 1.3% (Low) CVE2024-33883
2d	frontend/yarn.lock:4515	Needs reviewTransitiveASCAMPmainOPEN
1	nanoid: Infinite Loop	EPSS: 0.1% (Low) CVE2024-55565
2d	frontend/yarn.lock:7886	Needs reviewTransitiveASCAMPmainOPEN
1	webpack-dev-server: Exposed Dangerous Method or Function	EPSS: 0.4% (Low) CVE2025-30359
2d	frontend/yarn.lock:11700	Needs reviewTransitiveASCAMPmainOPEN
1	webpack-dev-server: Origin Validation Error	EPSS: 0.1% (Low) CVE2025-30360
2d	frontend/yarn.lock:11700	Needs reviewTransitiveASCAMPmainOPEN
1	js-yaml: Prototype Pollution	EPSS: <0.1% (Low) CVE2025-64718
2d	frontend/yarn.lock:7140	Needs reviewTransitiveASCAMPmainOPEN
1	node-forge: Integer Overflow or Wraparound	EPSS: <0.1% (Low) CVE2025-66030
2d	frontend/yarn.lock:7948	Needs reviewTransitiveASCAMPmainOPEN
1	yaml: Uncontrolled Recursion	EPSS: <0.1% (Low) CVE2026-33532
2d	frontend/yarn.lock:12133	Needs reviewTransitiveASCAMPmainOPEN
1	axios: Confused Deputy	EPSS: <0.1% (Low) CVE2025-62718
2d	frontend/yarn.lock:2750	Needs reviewDirectASCAMPmainOPEN

1	axios: HTTP Request/Response Splitting	EPSS: <0.1% (Low) CVE 2026-40175
1	2d frontend/yarn.lock:2750	Reachable Direct ASCASM main OPEN
1	follow-redirects: Exposure of Sensitive Information to an Unauthorized Actor	GHSA r4q5-vmmm-2653
1	2d frontend/yarn.lock:5350	Needs review Transitive ASCASM main OPEN
2	serve-static: Cross-site Scripting	EPSS: 0.9% (Low) CVE 2024-43800
2	2d frontend/yarn.lock:10386	Needs review Transitive ASCASM main OPEN
2	2d backend/yarn.lock:1109	Needs review Transitive ASCASM main OPEN
2	send: Cross-site Scripting	EPSS: 0.2% (Low) CVE 2024-43799
2	2d frontend/yarn.lock:10340	Needs review Transitive ASCASM main OPEN
2	2d backend/yarn.lock:1090	Needs review Transitive ASCASM main OPEN
2	express: Cross-site Scripting	EPSS: 0.1% (Low) CVE 2024-43796
2	2d frontend/yarn.lock:5111	Needs review Transitive ASCASM main OPEN
2	2d backend/yarn.lock:389	Needs review Direct ASCASM main OPEN
2	cookie: Injection	EPSS: 0.2% (Low) CVE 2024-47764
2	2d frontend/yarn.lock:3721	Needs review Transitive ASCASM main OPEN
2	2d backend/yarn.lock:280	Needs review Transitive ASCASM main OPEN
2	brace-expansion: Uncontrolled Resource Consumption	EPSS: <0.1% (Low) CVE 2025-5889
2	2d frontend/yarn.lock:3059	Needs review Transitive ASCASM main OPEN
2	2d backend/yarn.lock:157	Needs review Transitive ASCASM main OPEN
2	qs: Improper Input Validation	EPSS: <0.1% (Low) CVE 2026-2391
2	2d frontend/yarn.lock:9431	Needs review Transitive ASCASM main OPEN
2	2d backend/yarn.lock:968	Needs review Transitive ASCASM main OPEN
1	node-forge: Prototype Pollution	GHSA 5rrq-pxf6-6jx5
1	2d frontend/yarn.lock:7948	Needs review Transitive ASCASM main OPEN
1	es5-ext: Inefficient Regular Expression Complexity	EPSS: 2.0% (Low) CVE 2024-27088
1	2d frontend/yarn.lock:4682	Needs review Transitive ASCASM main OPEN
1	elliptic: Improper Verification of Cryptographic Signature	EPSS: 2.9% (Low) CVE 2024-42461
1	2d frontend/yarn.lock:4525	Needs review Transitive ASCASM main OPEN
1	elliptic: Improper Handling of Length Parameter Inconsistency	EPSS: 0.2% (Low) CVE 2024-42460
1	2d frontend/yarn.lock:4525	Needs review Transitive ASCASM main OPEN
1	elliptic: Improper Verification of Cryptographic Signature	EPSS: 0.1% (Low) CVE 2024-42459
1	2d frontend/yarn.lock:4525	Needs review Transitive ASCASM main OPEN
1	elliptic: Improper Verification of Cryptographic Signature	EPSS: 0.3% (Low) CVE 2024-48949
1	2d frontend/yarn.lock:4525	Needs review Transitive ASCASM main OPEN

1	elliptic: Improper Verification of Cryptographic Signature EPSS: 0.2% (Low) CVE 2024-48948
2d frontend/yarn.lock:4525	Needs review Transitive ASCASM main OPEN
1	on-headers: Improper Handling of Unexpected Data Type EPSS: <0.1% (Low) CVE 2025-7339
2d frontend/yarn.lock:8202	Needs review Transitive ASCASM main OPEN
1	elliptic: Use of a Cryptographic Primitive with a Risky Implementation EPSS: <0.1% (Low) CVE 2025-14505
2d frontend/yarn.lock:4525	Needs review Transitive ASCASM main OPEN
1	@tootallnate/once: Incorrect Control Flow Scoping EPSS: <0.1% (Low) CVE 2026-3449
2d frontend/yarn.lock:1812	Needs review Transitive ASCASM main OPEN

